OurMocks

2027 CYCLE

MOCK · PRACTICE · CRACK

CUET UG

Computer Science

Network Security, Cyber Threats & Defenses

Malware Taxonomy, Attack Vectors, Firewalls, Cryptography, Digital Certificates & Cyber Law Frameworks

INSIDE
Concept Notes

INSIDE
Solved Examples

INSIDE
Practice MCQs + Solutions

Aligned to the latest official syllabus · Concept-first explanations

www.ourmocks.com

Syllabus Alignment

Section / Unit	Official NTA Syllabus Pointers	Core Focus & High-Yield Exam Traps
Section B1: Topic 7 (Class 12)	Cyber Threats & Malware: Threats and prevention from Virus, Worm, Trojan horse, Spam, Adware, Spyware, Ransomware.	Virus (requires host file execution) vs Worm (self-replicating, standalone) vs Trojan (non-replicating disguise).
Section B1: Topic 7 (Class 12)	Network Security & Defenses: HTTP vs HTTPS, Firewalls (Packet filtering, Stateful, Proxy), Cookies, Antivirus tools.	Firewall layer boundaries, Cookie tracking vs session state, HTTPS SSL/TLS hybrid encryption (asymmetric handshake + symmetric data).
Section B1: Topic 7 (Class 12)	Cyber Law & Ethics: IT Act 2000 & 2008 amendments, Intellectual Property Rights (IPR), Copyright, Patent, Trademark, Open source vs Proprietary, Hackers vs Crackers.	Digital Signature signing key (Sender's Private Key), IT Act Key Sections (66, 66C, 66D, 66E), Copyright (expression) vs Patent (invention).

EXAM PATTERN

Network Security questions in CUET Computer Science test precise technical definitions, legal provisions, and cryptographic mechanisms:

1. **Malware Replication Invariant:** A **Virus** attaches to a host executable file and cannot replicate without user execution. A **Worm** is a standalone program that self-replicates across network sockets automatically. A **Trojan Horse** disguises itself as legitimate utility software and **never replicates**.
2. **Digital Signature Signing Key:** A Digital Signature is created by encrypting the document's cryptographic hash using the **Sender's Private Key**. It is verified by anyone using the **Sender's Public Key**. Encrypting with a public key provides confidentiality, **not** a digital signature!
3. **Phishing vs Pharming:** Phishing relies on social engineering deception (fake emails/SMS directing to fraudulent websites). Pharming is a technical attack that poisons DNS caches to silently redirect users entering a legitimate URL to a counterfeit server IP.
4. **Firewall Tiers:** Packet Filtering operates at Layers 3–4 (IP, Port, Protocol). Stateful Inspection operates across Layers 3–5 (tracking active TCP connection handshakes). Application Proxy operates at Layer 7 (Deep Packet Inspection of HTTP/FTP payloads).
5. **Hacker vs Cracker:** A **Hacker** (White Hat) is an authorized security expert who probes systems to identify and remediate vulnerabilities ethically. A **Cracker** (Black Hat) breaches computer networks with malicious intent to steal data or disrupt services.
6. **IT Act 2000 Provisions:** Grants legal validity to electronic documents and digital signatures. Section 66 penalizes computer-related offenses and hacking with imprisonment up to 3 years and fines up to ₹5 lakh.

Cyber Security Fundamentals & The CIA Triad

Cyber Security comprises the technologies, processes, and defensive controls designed to protect computer systems, communication networks, digital devices, and sensitive data from malicious attacks, unauthorized access, electronic espionage, and service disruption.

The Classic CIA Security Triad & Extended Guarantees

Every enterprise information security policy is anchored by three foundational security pillars, complemented by two operational guarantees:

1. **Confidentiality:** Ensuring that sensitive information is accessible strictly to authorized individuals, entities, or processes. Confidentiality prevents unauthorized disclosure through cryptographic data encryption (AES-256), strict role-based access control (RBAC), multi-factor authentication, and data classification.
2. **Integrity:** Safeguarding the accuracy, completeness, and trustworthiness of data throughout its entire lifecycle. Integrity guarantees that information has not been altered, forged, deleted, or tampered with in transit or storage. Implemented using cryptographic hash functions (SHA-256), message authentication codes (HMAC), and digital signatures.
3. **Availability:** Ensuring that authorized users have prompt, uninterrupted, and reliable access to computer resources, networks, and services whenever needed. Defended using hardware redundancy (RAID, server clustering), high-bandwidth internet connections, automated backups, and mitigation against Denial of Service (DoS) attacks.

- **Authenticity:** The verification that a communicating entity, sender, or digital document is genuine and genuinely originates from the purported source. Verified via digital certificates and PKI.
- **Non-Repudiation:** A legal and cryptographic property ensuring that a sender cannot falsely deny having created, signed, or transmitted a specific digital message or financial transaction. Achieved exclusively through **Digital Signatures**.

Comprehensive Malware Taxonomy

Malware (Malicious Software) is any program, script, or code construct intentionally engineered to infiltrate, compromise, damage, or gain unauthorized control over computing devices and computer networks.

1. Computer Viruses

A **Computer Virus** is a parasitic program fragment that inserts its malicious code into legitimate host executable files (`.exe`, `.com`, `.dll`, macro-enabled `.docx`/`.xlsx` documents) or disk storage sectors:

- **Execution Dependency:** A virus **cannot activate or propagate independently**. It remains dormant on storage media until a human user executes the infected host program or boots from an infected drive.
- **Infection Vectors:**
  - **File Infectors:** Attach to binary program files. When the user runs the application, the virus code executes in memory first before passing control back to the host program.
  - **Boot Sector Viruses:** Infiltrate the Master Boot Record (MBR) of hard disks or USB drives, loading into memory during the operating system's initial bootstrap sequence before antivirus software initializes.
  - **Macro Viruses:** Written in application scripting languages (VBA in Microsoft Office). Propagate across user templates and execute automatically when a document is opened.

2. Computer Worms

A **Computer Worm** is an autonomous, standalone malicious program that replicates itself and propagates across computer networks without requiring human activation or attachment to a host file:

- **Operational Mechanism:** Worms actively scan network segments for unpatched software vulnerabilities, open network ports, or weak credentials. Once a vulnerable node is discovered, the worm transmits a copy of itself over the network socket and executes autonomously.
- **Damage Profile:** Unlike viruses that primarily corrupt local files, worms consume massive network transmission bandwidth, exhaust router memory queues, and establish distributed botnets (e.g., the historic Morris Worm of 1988, Code Red, Conficker).

3. Trojan Horses

A **Trojan Horse** is malicious software concealed within an apparently useful, attractive, or benign utility application (e.g., a free game, illegal software crack, video codec, or system performance booster):

- **Replication Invariant (CUET High-Yield):** Trojan Horses **strictly DO NOT replicate or self-propagate**. They rely entirely on social engineering deception to entice users into downloading and installing them.
- **Payload Operations:** Once executed, Trojans secretly open unauthorized network backdoors (Remote Access Trojans / RATs), disable Windows Defender or local firewalls, install keystroke loggers, or turn the host machine into an enslaved **Zombie** controlled by a remote attacker.

4. Ransomware

Ransomware is an aggressive category of extortion malware that infiltrates a computer, discovers user files, and encrypts them using industrial-grade cryptographic algorithms (e.g., AES-256 for data files, with the AES key encrypted using the attacker's public RSA-2048 key):

- **Extortion Mechanism:** The malware displays an unclosable lockscreen or text ransom note informing the victim that their files are encrypted and demanding payment (typically in Bitcoin or Monero) within a strict time countdown in exchange for the private decryption key.
- **Defense Strategy:** Maintaining immutable, air-gapped, offline data backups. Paying the ransom provides zero legal guarantee that the criminals will supply a working decryption tool.

5. Spyware, Adware & Keyloggers

- **Spyware:** Stealth surveillance software installed silently alongside free software downloads. Monitors browsing habits, tracks geolocation, scans local storage, and transmits sensitive surveillance data to remote advertising servers.
- **Keyloggers:** Specialized spyware that hooks into operating system keyboard drivers to record every single physical keystroke typed by the user (capturing online banking passwords, credit card numbers, and private chat messages) and writes them to an encrypted log file uploaded to the attacker.
- **Adware:** Software that aggressively generates unwanted, intrusive pop-up advertisements, banner overlays, or alters browser homepage and search engine defaults without user consent.

Cyber Threats & Defense Taxonomy Matrix

CUET UG Computer Science (Code 308) · Malware Propagation, User Action Dependency, Impact & Defense Mechanisms

NTA THREAT INVARIANTS

THREAT CATEGORY	PROPAGATION VECTOR	USER ACTION?	PAYLOAD DAMAGE MECHANISM	PRIMARY DEFENSE	CUET EXAM DISTINGUISHER
Computer Virus	Attaches to executable host files (`.exe`, `.docx`)	Yes (Must run file)	Corrupts files, modifies boot sector, wipes disks	Signature Antivirus	Parasitic; *cannot* propagate without host file execution
Computer Worm	Network ports & OS socket vulnerabilities	No (Self-propagates)	Exhausts network bandwidth, creates botnet zombies	Patching & Firewalls	Standalone; replicates automatically across network links
Trojan Horse	Disguised as useful software (games, cracks)	Yes (User installs)	Installs backdoors, disables firewalls, rootkits	App whitelisting	*Does not replicate*; relies entirely on deception
Ransomware	Phishing attachments, drive-by downloads	Yes (Opens link)	Encrypts user data using asymmetric ciphers (AES/RSA)	Offline backups	Demands cryptocurrency ransom for decryption key
Spyware / Keylogger	Bundled with freeware, malicious browser ads	Yes (Silent install)	Logs keystrokes, steals passwords & credentials	Anti-spyware tools	Stealth surveillance; transmits telemetry to remote C2
Phishing	Spoofed emails, fake banking landing pages	Yes (Enters info)	Harvests login credentials, 2FA codes, credit cards	2FA & User awareness	Social engineering trickery; relies on user credulity
Pharming	DNS cache poisoning, local `hosts` file modification	No (URL is valid)	Silently redirects correct URL to counterfeit server IP	DNSSEC verification	Technical attack; user types 100% correct URL but redirected
DoS / DDoS	Flooding packet streams (SYN flood, UDP storm)	No (Target server)	Exhausts server CPU/bandwidth, causes service outage	Rate-limiting & CDN	Target is availability; does not steal or corrupt data

Core Distinctions: Virus (Host-dependent) vs Worm (Self-replicating) vs Trojan (Non-replicating disguise) vs Pharming (DNS redirection)

© OurMocks Education · CUET UG Computer Science

Figure 1: Cyber Threats & Defense Taxonomy Matrix: Propagation Vectors, User Action Requirements & Defensive Countermeasures

Cyber Attack Vectors & Exploitation Techniques

Cyber adversaries deploy an extensive array of social engineering and technical network intrusion methods to compromise digital assets.

1. Denial of Service (DoS) & Distributed Denial of Service (DDoS)

A **Denial of Service (DoS)** attack aims to render a target server, website, or network infrastructure completely unavailable to legitimate authorized users by deliberately exhausting its processing capacity, memory buffers, or network bandwidth:

- **Attack Mechanisms:**
  - **SYN Flood Attack:** Exploits the TCP 3-Way Handshake. The attacker floods the target server with thousands of `SYN` connection requests from spoofed, unreachable IP addresses. The server allocates socket memory and responds with `SYN-ACK`, waiting in a half-open state for the final `ACK`. The connection pool is rapidly saturated, blocking legitimate users.
  - **Ping of Death & ICMP Floods:** Overwhelming network interfaces with malformed or oversized ICMP packets.
- **Distributed DoS (DDoS):** The attack originates simultaneously from hundreds of thousands of geographically dispersed computers infected with malware (**Zombies**), coordinated as a unified **Botnet** commanded by a central attacker (**Botmaster**). Mitigated using Cloudflare/Akamai scrubbing centers and rate limiting.

2. Social Engineering: Phishing, Spear Phishing & Whaling

Social Engineering exploits human psychology, fear, urgency, and trust rather than software vulnerabilities:

- **Phishing:** Mass broadcasting of fraudulent, deceptive emails or SMS text messages mimicking legitimate organizations (banks, income tax departments, universities) directing users to counterfeit websites to harvest login credentials and debit card PINs.
- **Spear Phishing:** Highly customized, tailored phishing attacks targeted at a specific individual or organization, utilizing gathered background intelligence (e.g., job titles, vendor names) to increase credibility.
- **Whaling:** A spear phishing attack directed exclusively at high-profile corporate executives (CEOs, CFOs) or senior government officials to authorize massive wire transfers or exfiltrate intellectual property.

3. Technical Redirection: Pharming & DNS Spoofing

While phishing requires the user to click a suspicious hyperlink, **Pharming** is an advanced technical attack that invisibly manipulates the domain resolution process:

- **Attack Vectors:** The attacker compromises an upstream DNS server (**DNS Cache Poisoning**) or modifies the client's local operating system `hosts` file.
- **The Invariant:** Even when the user enters the **100% correct, genuine URL** (e.g., `https://www.mybank.com`) into their browser, the poisoned DNS resolver returns the attacker's counterfeit web server IP address. The user is presented with an identical clone website that captures credentials. Defended using **DNSSEC (DNS Security Extensions)**.

4. Identity Forgery: Spoofing & Eavesdropping

- **IP Spoofing:** Falsifying the source IP address in the header of an IP packet to trick the receiving firewall into believing the packet originates from a trusted internal workstation.
- **MAC Spoofing:** Changing the burned-in MAC address of a network interface card in software to bypass router MAC address filtering lists.
- **Email Spoofing:** Forging email `From:` headers (e.g., `From: principal@school.edu`) to conduct social engineering fraud.
- **Man-in-the-Middle (MitM) Attacks:** An attacker secretly intercepts and manipulates communication packets flowing between two communicating parties (e.g., between a laptop and a public coffee shop Wi-Fi router) using ARP poisoning. The attacker can modify packet contents in real time without either party detecting the breach.
- **Packet Sniffing:** Running protocol analyzers (Wireshark, tcpdump) on a network interface configured in **promiscuous mode** to capture all unencrypted cleartext data packets (Telnet, HTTP, FTP) traversing the local broadcast channel.

Cryptographic Systems: Symmetric, Asymmetric & Hashing

Cryptography is the mathematical science of transforming readable plaintext information into unintelligible ciphertext to ensure data privacy, confidentiality, and integrity.

Fundamental Cryptographic Terminology

- **Plaintext (P):** The original, readable message or document.
- **Ciphertext (C):** The encrypted, unreadable scrambled form of the message.
- **Encryption (E):** The mathematical transformation of plaintext into ciphertext using an algorithm and a key: $C = E_{K(P)}$.
- **Decryption (D):** The reverse transformation of ciphertext back into original plaintext: $P = D_{K(C)}$.
- **Cryptographic Key (K):** A secret binary value or string of bits that parameterizes the cryptographic algorithm.

1. Symmetric Key Cryptography (Secret-Key / Private-Key)

In **Symmetric Cryptography**, the **exact same single secret key** is utilized for both encryption and decryption:

- **Mathematical Formulation:**
$$C = E_{K(P)} \quad \text{and} \quad P = D_{K(C)}$$
- **Prominent Algorithms:** Advanced Encryption Standard (AES-128, AES-256), Data Encryption Standard (DES, 56-bit key), Triple-DES (3DES).
- **Advantages:** Highly optimized for execution speed; encrypts gigabytes of data per second with minimal CPU load.
- **The Fundamental Limitation (Key Distribution Problem):** Both sender and receiver must securely share the exact secret key prior to communication. If the key is transmitted over an unencrypted network, it can be intercepted, compromising the entire system. Furthermore, for n users to communicate mutually, a total of $\frac{n(n-1)}{2}$ unique keys must be managed!

2. Asymmetric Key Cryptography (Public-Key Cryptography)

Invented by Whitfield Diffie and Martin Hellman in 1976, **Asymmetric Cryptography** deploys a mathematically coupled pair of keys: a **Public Key** (made freely available to the entire world) and a **Private Key** (kept strictly secret by the owner):

- **Dual-Key Mechanics:** Data encrypted with one key of the pair can **strictly only be decrypted by the matching corresponding key** of that same pair!
    1. **For Confidentiality (Privacy):** The sender encrypts the plaintext using the **Recipient's Public Key**. Only the recipient possessing the matching **Recipient's Private Key** can decrypt it:

$$C = E_{K_{\text{pub, recipient}}}(P) \quad \Longrightarrow \quad P = D_{K_{\text{priv, recipient}}}(C)$$

2. **For Authentication & Digital Signatures:** The sender encrypts data using their own **Sender's Private Key**. Anyone can decrypt and verify it using the **Sender's Public Key**:

$$S = E_{K_{\text{priv, sender}}}(P) \quad \Longrightarrow \quad P = D_{K_{\text{pub, sender}}}(S)$$

- **Prominent Algorithms:** RSA (Rivest-Shamir-Adleman, based on prime factorization), ECC (Elliptic Curve Cryptography), Diffie-Hellman Key Exchange.
- **Trade-offs:** Solves the key distribution problem completely, but is computationally intensive (approximately 1,000 times slower than symmetric AES). Modern networks combine both: asymmetric encryption secures the initial handshake, and symmetric encryption transfers the actual bulk payload.

3. Cryptographic Hash Functions & Message Digests

A **Cryptographic Hash Function** (H) is a one-way mathematical algorithm that takes a variable-length input message and compresses it into a unique, fixed-size binary string called a **Message Digest** or **Hash**:

- **Core Properties:**
  1. **One-Way Property (Pre-image Resistance):** Given a hash digest h, it is computationally impossible to reconstruct the original message M such that $H(M) = h$.
  2. **Collision Resistance:** It is computationally infeasible to discover two completely different input messages M_1 and M_2 that yield the exact same hash output ($H(M_1) = H(M_2)$).
  3. **Avalanche Effect:** Modifying even a single binary bit in a multi-gigabyte document causes the resulting hash digest to change drastically and unpredictably.
- **Standard Algorithms:** SHA-256 (Secure Hash Algorithm, producing 256-bit digests), SHA-3, MD5 (128 bits, legacy/deprecated due to collision vulnerabilities).

RSA CRYPTOGRAPHIC NUMERICAL CALCULATION

Problem: In a simplified RSA asymmetric cryptosystem, the prime numbers chosen are $p = 3$ and $q = 11$.

1. Calculate the modulus n and Euler's totient function $\varphi(n)$.
2. If the public encryption key is chosen as $e = 7$, compute the private decryption key d.
3. Encrypt the plaintext message $M = 2$ to find the ciphertext C.

Solution:

- **Part 1:** Calculate n and $\varphi(n)$:

$$n = p \times q = 3 \times 11 = 33$$
$$\varphi(n) = (p-1)(q-1) = (3-1)(11-1) = 2 \times 10 = 20$$

- **Part 2:** The private key d is the multiplicative modular inverse of e modulo $\varphi(n)$:

$$d \times e \equiv 1 (\text{mod}\, \varphi(n)) \quad \Longrightarrow \quad d \times 7 \equiv 1 (\text{mod}\, 20)$$

Testing values: for $d = 3$, $3 \times 7 = 21 = (1 \times 20) + 1 \equiv 1 (\text{mod}\, 20)$. Thus, $d = 3$.

- **Part 3:** Encrypt plaintext $M = 2$:

$$C = M^e (\text{mod}\, n) = 2^7 (\text{mod}\, 33) = 128 (\text{mod}\, 33) = 128 - (3 \times 33) = 128 - 99 = 29$$

The ciphertext is **29**. (Verification: $C^d (\text{mod}\, n) = 29^3 (\text{mod}\, 33) = 24389 (\text{mod}\, 33) = 2 = M$).

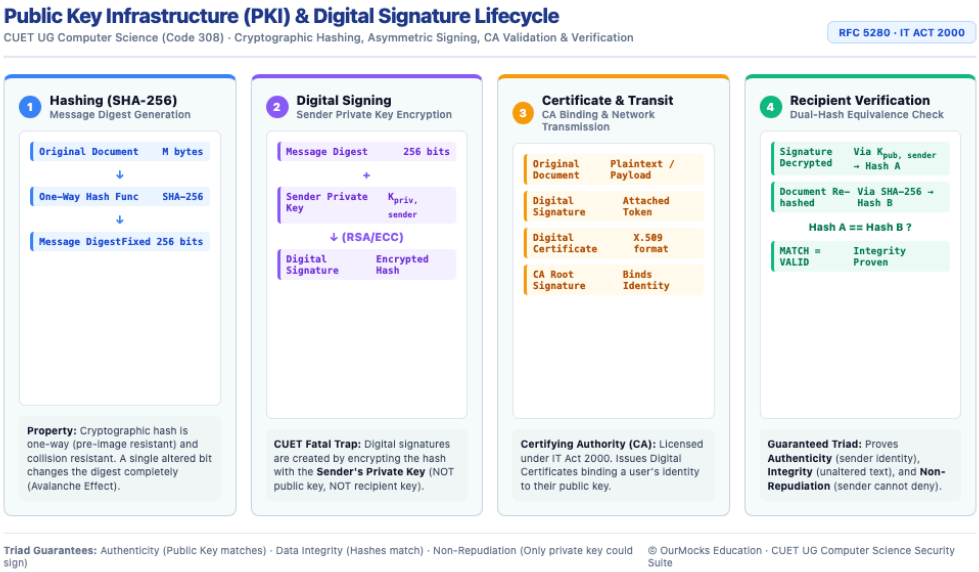


Figure 2: Public Key Infrastructure (PKI) & Digital Signature Lifecycle: Hash Generation, Signing, Transit & Verification

Public Key Infrastructure (PKI) & Digital Signatures

Public Key Infrastructure (PKI) is the integrated framework of hardware, software, cryptographic policies, and legal standards that manages the generation, distribution, validation, and revocation of digital certificates and public keys.

1. Digital Signatures: Creation & Verification Workflow

A **Digital Signature** is a mathematical cryptographic mechanism that binds an electronic document to the identity of the signer, providing absolute proof of **Authenticity**, **Data Integrity**, and **Non-Repudiation**:

- **Step-by-Step Signing Lifecycle:**
  1. **Step 1 (Hash Generation):** The sender passes the original digital document through a cryptographic hash function (SHA-256) to produce a fixed-length **Message Digest** (H_1).
  2. **Step 2 (Signing):** The sender encrypts this message digest using the **Sender's Private Key** ($K_{\text{priv, sender}}$). The resulting encrypted digest is the **Digital Signature** (S):
  $$S = E_{K_{\text{priv, sender}}}(H_1)$$
  3. **Step 3 (Transmission):** The sender transmits the original document along with the attached Digital Signature across the network to the recipient.
  4. **Step 4 (Verification by Recipient):**
     - The recipient decrypts the digital signature using the **Sender's Public Key** ($K_{\text{pub, sender}}$) to recover the original hash digest (H_1):
     $$H_1 = D_{K_{\text{pub, sender}}}(S)$$
     - The recipient independently computes a fresh hash digest (H_2) of the received document using the exact same SHA-256 algorithm.
     - **Equivalence Test:** The recipient compares H_1 and H_2. If $H_1 == H_2$, the signature is 100% valid!
- **Cryptographic Proofs Established:**
  - **Integrity:** If an attacker altered even a single comma in the document during transmission, $H_2 \neq H_1$, instantly exposing tampering.
  - **Authenticity & Non-Repudiation:** Because the signature could only be decrypted using the sender's public key, it mathematically proves that it could **strictly only have been created by the sender possessing the unique matching private key**.

2. Digital Certificates & Certifying Authorities (CA)

- **The Man-in-the-Middle Vulnerability:** If an attacker intercepts public key distribution and distributes a fake public key impersonating a bank, how can a user know a public key genuinely belongs to the bank?
- **Digital Certificate (X.509 Standard):** An electronic credential issued by a trusted third party called a **Certifying Authority (CA)** (e.g., VeriSign, DigiCert, eMudhra in India under the IT Act 2000).
- **Certificate Contents:**
  - Owner's Public Key and Owner's Registered Identity (Domain Name, Company Name).
  - Digital Certificate Serial Number, Expiration Date, and Algorithm Identifier.
  - **The Digital Signature of the Certifying Authority:** The CA cryptographically signs the certificate using the **CA's own Private Key**, guaranteeing that the public key belongs to the verified entity.

Network Defensive Architecture: Firewalls & Network Isolation

A comprehensive cybersecurity defense relies on defense-in-depth principles combining multi-tier firewalls, intrusion detection engines, and segregated network topologies.

1. Network Firewalls: The Three Core Architectural Tiers

A **Firewall** is a hardware appliance or software engine positioned at network boundaries that inspects, filters, and controls incoming and outgoing packet traffic according to a defined security policy:

- **Tier 1: Packet Filtering Firewall (Stateless — Layers 3 & 4):**
  - Inspects individual packet headers independently without maintaining connection state memory. Evaluates Access Control Lists (ACLs) against: Source IP, Destination IP, Transport Protocol (TCP/UDP), and Port numbers.
  - **Strengths & Weaknesses:** High throughput and low latency, but blind to payload content and easily bypassed by IP spoofing.
- **Tier 2: Stateful Inspection Firewall (Layers 3, 4 & 5):**
  - Maintains a dynamic **State Table** tracking active TCP connections (Three-Way Handshake states). It only permits incoming packets if they match an established, legitimate outbound session initiated from inside the trusted network. Automatically drops unsolicited external packets.
- **Tier 3: Application Proxy Firewall / Next-Generation Firewall (NGFW — Layer 7):**

- Acts as an active intermediary (proxy) for application traffic. Conducts **Deep Packet Inspection (DPI)** of application payloads, reassembles HTTP streams, inspects URLs, blocks SQL injection keywords, strips malicious email attachments, and enforces user access controls.

2. Intrusion Detection Systems (IDS) vs Intrusion Prevention Systems (IPS)

- **Intrusion Detection System (IDS):** A passive monitoring sensor placed out-of-band on a switch mirror port. Analyzes network traffic patterns against a database of known attack signatures (Signature-based IDS) or statistical baselines (Anomaly-based IDS). Generates administrative alerts when an intrusion occurs, but **does not block traffic**.
- **Intrusion Prevention System (IPS):** An active inline device positioned directly in the communication path. When malicious traffic is detected, the IPS drops the malicious packets in real time and automatically reconfigures firewall rules to block the attacker's IP address.

3. Demilitarized Zone (DMZ) Architecture

A **DMZ** is a physical or logical subnetwork that isolates an organization's public-facing servers (Web Servers, Mail Servers, DNS Servers) from its internal private corporate LAN using a dual-firewall architecture. If a public web server in the DMZ is compromised by an external hacker, the internal firewall prevents the hacker from pivoting into the internal database and workstation network.

Web Security, Identity & Authentication Controls

1. Web Security: Cookies & Session Management

- **HTTP Cookies:** Small plaintext key-value pairs stored on the client's local drive by web servers:
  - **Session Cookies:** Stored temporarily in volatile RAM; deleted automatically when the web browser is closed. Manages e-commerce shopping carts.
  - **Persistent Cookies:** Written to disk with a defined expiration date; remembers login credentials, language preferences, and user themes across multiple browser restarts.
  - **Third-Party Tracking Cookies:** Planted by external advertising networks to track user browsing behavior across disparate websites for behavioral marketing profiles.
- **Security Risks:** Cookies can be stolen via Cross-Site Scripting (XSS) or intercepted over unencrypted HTTP, enabling **Session Hijacking**. Mitigated using the `Secure` flag (forces HTTPS transmission) and `HttpOnly` flag (blocks JavaScript access).

2. Multi-Factor Authentication (MFA)

Authentication confirms a user's claimed identity before granting access. Modern systems mandate **Multi-Factor Authentication (MFA)**, requiring credentials from at least two distinct authentication factors:

1. **Knowledge Factor (Something You Know):** Passwords, PINs, security questions.
2. **Possession Factor (Something You Have):** Physical smart cards, hardware security keys (YubiKey), Time-based One-Time Password (TOTP) authenticator apps, SMS OTPs.
3. **Inherence Factor (Something You Are):** Biometrics (fingerprint scans, facial recognition, iris patterns, voice recognition).

Advanced Web Vulnerabilities, Injection Attacks & Exploit Defense

Modern distributed web architectures face application-layer vulnerabilities that bypass traditional network packet-filtering firewalls.

1. Structured Query Language (SQL) Injection

SQL Injection (SQLi) occurs when untrusted user input is concatenated directly into a dynamic backend database SQL query without prior syntactic validation, sanitization, or parameterization:

- **Attack Mechanics — Tautology Exploitation:** Consider an insecure authentication script executing the query: `SELECT * FROM USERS WHERE username = '` + input_user + `' AND password = '` + input_pass + `';` If an attacker inputs `admin' --` into the username field, the resulting executed query becomes: `SELECT * FROM USERS WHERE username = 'admin' -- AND password = '...';` Because `--` denotes a SQL comment, the entire password verification clause is truncated and ignored! The database unconditionally returns the administrator record, granting unauthorized access. Alternatively, submitting input `' OR 1=1 --` produces an invariant tautology ($1 = 1$ is always true), dumping the entire database table.
- **Defensive Countermeasures:**
  1. **Prepared Statements (Parameterized Queries):** Forces the database engine to compile the SQL query template **before** binding user variables, ensuring user input is treated strictly as data literals, never as executable SQL code.
  2. **Stored Procedures & Input Validation:** Enforcing strict allow-lists and input data type checking.
  3. **Principle of Least Privilege:** Restricting web database accounts to read-only access where modification is unnecessary.

2. Cross-Site Scripting (XSS) & Session Hijacking

Cross-Site Scripting (XSS) occurs when a web application accepts malicious client-side JavaScript code from an attacker and reflects it into web pages served to other legitimate users:

- **XSS Categories:**
  - **Stored / Persistent XSS:** Malicious JavaScript is submitted (e.g., in a blog comment or forum post) and stored permanently in the backend database. Every subsequent user who views the page executes the malicious script in their local browser.
  - **Reflected / Non-Persistent XSS:** Malicious payload is embedded inside a URL query parameter (e.g., `https://site.com/search?q=<script>...</script>`). When the victim clicks the link, the server reflects the payload back in the search result.
  - **DOM-Based XSS:** Vulnerability exists entirely within client-side JavaScript code directly manipulating the Document Object Model.
- **Damage Mechanism — Cookie Theft & Session Hijacking:** The injected JavaScript accesses the browser's `document.cookie` object, extracts the victim's session authentication token, and silently transmits it to an attacker-controlled server. The attacker clones the session token into their own browser and impersonates the authenticated victim.
- **Defenses:** Context-aware output encoding (escaping `<, >, &, ", '`), enforcing **Content Security Policy (CSP)** HTTP response headers, and setting the `HttpOnly` flag on sensitive cookies.

3. Buffer Overflow Exploits

A **Buffer Overflow** occurs when a computer program written in memory-unsafe languages (such as C or C++) writes more data into a fixed-size memory buffer on the call stack than the buffer was allocated to hold:

- **Stack Smashing:** The excess data spills over adjacent memory locations, overwriting the function's stored **Return Instruction Pointer (EIP/RIP)** on the stack. The attacker points the return address to injected malicious machine code (**Shellcode**), seizing complete CPU control.
- **Mitigation:** Using memory-safe programming languages (Python, Java, Rust), enabling **Address Space Layout Randomization (ASLR)**, and configuring non-executable stacks (**Data Execution Prevention / DEP / NX-bit**).

Classical Cryptographic Ciphers & Key Exchange Protocols

1. Classical Substitution Ciphers

- **Caesar Cipher (Monoalphabetic Shift Cipher):** Replaces each plaintext letter with a letter fixed k positions down the alphabet:
$$C = (P + k) (\mathrm{mod}\, 26) \quad \text{and} \quad P = (C - k) (\mathrm{mod}\, 26)$$
Easily cracked using brute-force (only 25 possible keys) or frequency analysis (the letter 'E' is the most frequent in English).
- **Vigenère Cipher (Polyalphabetic Cipher):** Uses a repeating keyword to shift letters by varying offsets, flattening single-letter frequency spikes.

DIFFIE-HELLMAN KEY EXCHANGE NUMERICAL ANALYSIS

Problem: Two network engineers, Alice and Bob, agree to use the Diffie-Hellman public key exchange protocol with public prime $p = 23$ and public base (primitive root) $g = 5$.

1. Alice chooses a secret private key $a = 6$. Calculate Alice's public key A.
2. Bob chooses a secret private key $b = 15$. Calculate Bob's public key B.
3. Calculate the shared secret session key K established by Alice and Bob independently.

Solution:

- **Part 1:** Alice calculates public key A:
$$A = g^a (\mathrm{mod}\, p) = 5^6 (\mathrm{mod}\, 23) = 15625 (\mathrm{mod}\, 23)$$
$$15625 = (679 \times 23) + 8 \implies A = 8$$
- **Part 2:** Bob calculates public key B:
$$B = g^b (\mathrm{mod}\, p) = 5^{\{15\}} (\mathrm{mod}\, 23)$$
Using modular exponentiation: $5^2 = 25 \equiv 2 (\mathrm{mod}\, 23)$; $5^4 \equiv 4 (\mathrm{mod}\, 23)$; $5^8 \equiv 16 \equiv -7 (\mathrm{mod}\, 23)$;
$$5^{\{15\}} = 5^8 \times 5^4 \times 5^2 \times 5^1 \equiv (-7) \times 4 \times 2 \times 5 = -280 (\mathrm{mod}\, 23) = 19$$
Bob's public key is **19**.
- **Part 3:** Alice computes shared key: $K = B^a (\mathrm{mod}\, p) = 19^6 (\mathrm{mod}\, 23) = 2$. Bob computes shared key: $K = A^b (\mathrm{mod}\, p) = 8^{\{15\}} (\mathrm{mod}\, 23) = 2$. Both parties independently arrive at the identical shared secret key **2** without ever transmitting it over the wire!

Digital Footprints, Data Privacy & Software Licensing Models

1. Digital Footprints: Active vs Passive Trails

A **Digital Footprint** is the persistent trail of traceable digital data left behind by an individual as a consequence of their interactions across electronic networks, websites, and mobile applications:

- **Active Digital Footprints:** Created intentionally and deliberately by the user. Includes posting photographs or messages on social media, sending emails, filling out online registration forms, publishing blog entries, and agreeing to location check-ins.
- **Passive Digital Footprints:** Generated unintentionally and invisibly without the user's active awareness. Includes web server access logs (recording client IP address, operating system, and browser version), geographic tracking via mobile cellular base stations, and telemetry gathered by tracking cookies across e-commerce portals.
- **Digital Footprint Hygiene:** Practicing cautious information sharing, reviewing application permissions, configuring privacy settings, and utilizing VPNs and incognito browsing.

2. Free and Open Source Software (FOSS) Licensing Framework

Software distributions adhere to standardized intellectual property licenses that define rights to inspect, modify, and distribute code:

License Type	Philosophy	Source Code Rights	Redistribution & Derivative Terms
GNU GPL (General Public)	Copyleft / Free Software	Mandatory source code access	Any derivative work **must** also be released under the identical GPL license (Strong Copyleft).
MIT License	Permissive Open Source	Full source code access	Permits anyone to modify, sublicense, and sell code in proprietary products with minimal attribution.
Apache 2.0	Permissive with Patents	Full source code access	Permits commercial use, modification, and distribution; includes explicit patent rights grant.
Creative Commons	Modular Content Rights	Applies to media, art, text	Allows creators to configure CC-BY (Attribution), CC-NC (Non-Commercial), CC-SA (ShareAlike).
Proprietary (EULA)	Closed Commercial	Strictly closed / compiled	No decompilation, reverse engineering, or unauthorized distribution permitted.

Cyber Law, Information Technology Act 2000 & Intellectual Property Rights

As society transitioned into electronic commerce and digital governance, specialized legal frameworks were enacted to regulate cyber activities and penalize electronic crimes.

1. The Information Technology Act, 2000 (IT Act 2000)

Enacted by the Parliament of India in May 2000 (and substantially amended in 2008), the IT Act 2000 is India's primary legislation governing cyber crime, electronic commerce, and digital communications.

- **Core Objectives:**
  1. Grants legal recognition to electronic transactions, digital records, and electronic signatures (substituting physical paper signatures).
  2. Provides legal framework for electronic filing of documents with government agencies (e-Governance).
  3. Establishes legal authority for licensing Certifying Authorities (CAs) to issue Digital Signature Certificates.
  4. Formulates definitions and penal consequences for cyber crimes, unauthorized access, and computer data damage.

2. Key Penal Sections of the IT Act 2000 / 2008

- **Section 43:** Penalty for damage to computer systems, data theft, virus introduction, unauthorized downloading or copying of data. Imposes civil compensation to victims up to ₹1 crore.
- **Section 66 (Computer Related Offenses / Hacking):** Committing any act referred to in Section 43 dishonestly or fraudulently. Imprisonment up to **3 years** or fine up to **₹5 lakh**, or both.
- **Section 66B:** Punishment for dishonestly receiving stolen computer resources or communication devices.
- **Section 66C:** Punishment for identity theft (fraudulent use of another person's electronic signature, password, or unique identification feature). Imprisonment up to 3 years and fine up to ₹1 lakh.
- **Section 66D:** Punishment for cheating by personation using computer resources (phishing and electronic impersonation).

- **Section 66E:** Punishment for violation of bodily privacy (capturing, publishing, or transmitting images of private areas without consent).
- **Section 66F:** Punishment for **Cyber Terrorism** (threatening the unity, integrity, security, or sovereignty of India via electronic networks). Punishable with imprisonment for **life**.
- **Section 67:** Punishment for publishing or transmitting obscene material in electronic form.
- **(Note on Section 66A):** Section 66A (criminalizing offensive messages) was famously struck down by the Supreme Court of India in 2015 in the landmark **Shreya Singhal v. Union of India** ruling as unconstitutional and violative of freedom of speech.

3. Intellectual Property Rights (IPR) in the Digital Age

Intellectual Property refers to creations of the human mind: inventions, literary and artistic works, software code, symbols, names, and designs used in commerce:

- **Copyright:** Protects original literary, dramatic, musical, artistic works, and **computer software programs (source code and object code)**. Grants the creator exclusive rights to reproduce, distribute, and license the work. Automatically granted upon creation.
- **Patents:** Protects novel, non-obvious, and industrially applicable **inventions, hardware architectures, and technological processes**. Grants a 20-year monopoly to prevent others from manufacturing or selling the patented invention.
- **Trademarks:** Protects distinctive brand names, logos, slogans, and symbols used in commerce to distinguish goods/services (e.g., Apple logo, Google search brand).
- **Digital Piracy & Plagiarism:**
  - **Software Piracy:** The unauthorized copying, cracking, distribution, or commercial exploitation of copyrighted software.
  - **Plagiarism:** Copying another individual's text, ideas, or software code and presenting it as one's own original creation without proper citation.

4. Software Licensing Models & Cyber Ethics

- **Proprietary Software:** Source code is kept strictly closed and proprietary by the vendor (e.g., Microsoft Windows, Adobe Photoshop). Users purchase a restricted End User License Agreement (EULA).
- **Free and Open Source Software (FOSS):** Software whose source code is freely available for inspection, modification, and redistribution. Governed by licenses such as GNU General Public License (GPL), Apache, and MIT.
- **Creative Commons (CC):** Modular public licenses allowing creators to grant standardized permissions (Attribution, NonCommercial, ShareAlike).
- **Hacker vs Cracker Classification:**
  - **White Hat Hackers (Ethical Hackers):** Certified security analysts who perform authorized penetration testing with formal client permission to discover and remediate security flaws.
  - **Black Hat Hackers (Crackers):** Criminal actors who illegally penetrate networks without authorization to steal sensitive data, deploy ransomware, or vandalize infrastructure.
  - **Grey Hat Hackers:** Individuals who breach systems without authorization, but without malicious intent, often demanding a bounty or publicly disclosing the flaw.

Master Synthesis Mindmap: Network Security, Cyber Threats & Defenses



Figure 3: Master Synthesis Mindmap: Malware Taxonomy, Attack Vectors, PKI Cryptography, Firewalls & Cyber Law

OurMocks

Cheatsheet & The Seven Fatal CUET Traps

RAPID REVISION CHEATSHEET: NETWORK SECURITY, CYBER THREATS & DEFENSES

- **The CIA Triad:** Confidentiality (encryption, privacy), Integrity (hashing, unaltered data), Availability (uninterrupted access). Extended: Authenticity & Non-Repudiation (Digital Signatures).
- **Malware Taxonomy:**
  - **Virus:** Parasitic; attaches to host files (`.exe`). **Requires human execution** to propagate.
  - **Worm:** Standalone, self-replicating. Spreads across network sockets **without human action**. Consumes bandwidth.
  - **Trojan Horse:** Concealed as useful utility software; opens backdoors. **Never replicates**.
  - **Ransomware:** Cryptographically encrypts user files (AES/RSA); demands cryptocurrency ransom.
  - **Spyware / Keylogger:** Secret surveillance recording keystrokes and credentials.
- **Attack Vectors:**
  - **DoS / DDoS:** Traffic flooding (SYN flood, UDP storm) using zombie botnets. Attacks **Availability**.
  - **Phishing:** Social engineering emails spoofing legitimate institutions to harvest credentials.
  - **Pharming:** Technical DNS cache poisoning; silently redirects valid URLs to counterfeit IP servers.
  - **Spoofing:** Falsifying IP, MAC, or Email sender headers.
  - **MitM:** Real-time interception and tampering of packets traversing communication links.
- **Cryptography Systems:**
  - **Symmetric:** Single shared secret key (AES, DES). Ultra-fast, high throughput. Key distribution challenge.
  - **Asymmetric:** Public key (encrypts) + Private key (decrypts) (RSA, ECC). Solves key exchange.
  - **Hash Functions:** One-way fixed-size digest (SHA-256). Pre-image and collision resistant. Proves **Integrity**.
- **Digital Signatures & PKI:**
  - Created by encrypting message hash with **Sender's Private Key**.
  - Verified by decrypting signature with **Sender's Public Key** and matching document hashes.
  - Guarantees **Authenticity**, **Integrity**, and **Non-Repudiation**.
  - **Digital Certificate:** X.509 document binding identity to public key, signed by a Certifying Authority (CA).
- **Defensive Controls:**
  - **Packet Filter:** Layers 3–4 (IP, Port, Protocol). Stateless.
  - **Stateful Firewall:** Layers 3–5; tracks active TCP 3-way handshakes.
  - **Application Proxy:** Layer 7; Deep Packet Inspection (DPI).
  - **MFA:** Requires 2+ factors: Knowledge (password), Possession (OTP/token), Inherence (biometrics).
- **Cyber Law & Ethics:**
  - **IT Act 2000:** Legal validity of e-records & digital signatures. Section 66 (Hacking, up to 3 yrs prison / ₹5 lakh fine), Section 66C (Identity theft), Section 66D (Cheating by personation), Section 66F (Cyber terrorism, life prison).
  - **IPR:** Copyright (protects software source code), Patent (protects inventions/processes for 20 yrs), Trademark (protects brand names/logos).
  - **Hacker vs Cracker:** White hat (ethical, authorized) vs Black hat cracker (illegal, malicious).

THE SEVEN FATAL CUET TRAPS IN NETWORK SECURITY

1. **The Digital Signature Signing Key Trap:** A Digital Signature is created by encrypting the hash with the **Sender's Private Key**! If an exam question asks which key signs the document, the answer is **never** the public key or the recipient's key!
2. **The Virus vs Worm Replication Trap:** A Virus **cannot** propagate without user action (must execute host file). A Worm is a standalone program that self-replicates across networks **automatically without user interaction**.
3. **The Trojan Horse Non-Replication Trap:** A Trojan Horse **never replicates** or infects other files. It relies strictly on user deception to gain entry.
4. **The Phishing vs Pharming Redirection Trap:** In Phishing, the user clicks a deceptive fake link. In Pharming, the user types the **100% genuine URL**, but poisoned DNS servers invisibly redirect them to an attacker's fake IP address!
5. **The DoS CIA Triad Target Trap:** A Denial of Service (DoS) attack does **not** steal or corrupt sensitive data (Confidentiality and Integrity remain intact). It exclusively attacks **Availability**!
6. **The Symmetric vs Asymmetric Key Count Trap:** For n mutual users, Symmetric encryption requires $\frac{n(n-1)}{2}$ secret keys. Asymmetric encryption requires strictly $2n$ total keys (each user has 1 public and 1 private key).
7. **The Software Copyright vs Patent Trap:** Computer software source code and programs are legally protected under **Copyright law** (as literary works), while hardware inventions and novel algorithmic processes are protected under **Patents**.

CUET Focused Multiple Choice Questions (Part 1)

Q1. Which category of malicious software is autonomous, operates as a standalone program, and self-replicates automatically across computer networks without requiring human execution or attachment to a host file?

(A) Computer Worm (B) Computer Virus
(C) Trojan Horse (D) Macro Virus

Sol. Q1. A Computer Worm is a standalone program that self-replicates and spreads across network sockets autonomously without requiring a host file or human intervention. In contrast, a virus requires a host executable, and a Trojan does not replicate.

Answer: (A)

Q2. In Public Key Cryptography, which cryptographic key is strictly utilized by the sender to generate a valid Digital Signature over a document's message digest?

(A) Recipient's Public Key (B) Sender's Private Key
(C) Sender's Public Key (D) Recipient's Private Key

Sol. Q2. A Digital Signature is generated by encrypting the document's hash digest using the Sender's Private Key. Because only the sender possesses this private key, anyone verifying the signature with the sender's public key receives proof of authenticity and non-repudiation.

Answer: (B)

Q3. An attacker poisons the local DNS cache of an internet service provider so that users typing the genuine banking web address are silently redirected to a counterfeit website. What is this attack formally called?

(A) Phishing (B) Denial of Service (DoS)
(C) Pharming (D) Man-in-the-Middle (MitM)

Sol. Q3. Pharming is an attack that manipulates DNS server resolution or local `hosts` files to invisibly redirect users to a malicious counterfeit server, even when the user enters the completely genuine, correct URL string.

Answer: (C)

Q4. Under the Indian Information Technology Act 2000 (as amended in 2008), what is the maximum punishment prescribed under Section 66 for hacking and fraudulent computer-related offenses?

(A) Fine up to ₹10,000 with no imprisonment (B) Imprisonment up to 1 year or fine up to ₹1 lakh
(C) Imprisonment for life with mandatory asset forfeiture (D) Imprisonment up to 3 years or fine up to ₹5 lakh, or both

Sol. Q4. Section 66 of the IT Act 2000 prescribes punishment for computer-related offenses (including hacking and data destruction) with imprisonment for a term which may extend to 3 years, or with a fine which may extend to ₹5 lakh, or both.

Answer: (D)

Q5. Which security property of the CIA triad is directly compromised when an attacker executes a SYN Flood Denial of Service (DoS) attack against an enterprise web portal?

(A) Availability (B) Confidentiality
(C) Integrity (D) Non-Repudiation

Sol. Q5. A Denial of Service (DoS) attack floods server socket buffers with bogus SYN requests, preventing legitimate users from accessing services. It does not steal data (Confidentiality) or alter data (Integrity); it exclusively attacks Availability.

Answer: (A)

CUET Focused Multiple Choice Questions (Part 2)

Q6. How many total unique secret keys must be distributed and managed if 10 independent corporate branch offices want to communicate mutually using Symmetric Key Cryptography?

(A) 20 keys **(B)** 45 keys
(C) 90 keys **(D)** 10 keys

Sol. Q6. In Symmetric Key Cryptography, each pair of communicating parties requires a unique shared secret key. For $n = 10$ users, the total keys required is given by the combination formula:

$$\frac{n(n-1)}{2} = \frac{10 \times 9}{2} = 45 \text{ keys}$$

(In contrast, Asymmetric cryptography would require strictly $2n = 20$ total keys).

Answer: (B)

Q7. Which tier of firewall hardware operates at Layer 7 of the OSI model and performs Deep Packet Inspection (DPI) of application payloads to block SQL injection and cross-site scripting attacks?

(A) Stateless Packet Filtering Firewall **(B)** Circuit-Level Gateway Firewall
(C) Application Proxy / Next-Generation Firewall **(D)** Network Address Translation (NAT) Router

Sol. Q7. An Application Proxy Firewall operates at the Application Layer (Layer 7). It reconstructs full application data streams, inspecting payload content, HTTP request headers, and data arguments to detect application-layer exploits such as SQL injection.

Answer: (C)

Q8. Under Intellectual Property Rights (IPR) law, which legal instrument is utilized to protect original computer software programs and source code from unauthorized duplication and distribution?

(A) Industrial Design Rights **(B)** Patent Protection
(C) Trademark Registration **(D)** Copyright

Sol. Q8. Computer software code, programs, and documentation are legally classified as "literary works" and are protected under Copyright law, granting creators exclusive rights to reproduce and distribute their source and binary code.

Answer: (D)

Q9. What is the essential distinction between a Session Cookie and a Persistent Cookie stored on a client's local computer?

(A) Session Cookies are stored in volatile RAM and deleted when the browser closes, whereas Persistent Cookies remain on the hard drive until expiration **(B)** Session Cookies are encrypted while Persistent Cookies are always plaintext
(C) Session Cookies are used exclusively by banking websites while Persistent Cookies are used by email servers **(D)** Session Cookies are stored on the server disk while Persistent Cookies are stored in router memory

Sol. Q9. Session cookies reside in temporary volatile memory and expire immediately when the browser session terminates. Persistent cookies are written to the client's hard disk with an explicit expiration date to preserve login state across sessions.

Answer: (A)

Q10. An ethical security researcher who possesses formal authorization from an organization to conduct penetration testing and identify system vulnerabilities is classified as what type of hacker?

(A) Black Hat Hacker (Cracker) **(B)** White Hat Hacker (Ethical Hacker)
(C) Script Kiddie **(D)** Cyber Terrorist

Sol. Q10. White Hat Hackers (Ethical Hackers) utilize security tools with legitimate permission and legal authorization to identify vulnerabilities, perform security auditing, and assist organizations in remediating defense flaws.

Answer: (B)

CUET Focused Multiple Choice Questions (Part 3)

Q11. Which authentication credential combination represents true Multi-Factor Authentication (MFA) utilizing two completely different authentication factors?

(A) Entering a password and a secret security question
(B) Entering an account username and a password
(C) Entering a password (knowledge) and scanning a fingerprint (inherence)
(D) Entering an ATM PIN and a telephone password

Sol. Q11. True MFA requires credentials from at least two distinct factor categories: Knowledge (something you know: password), Possession (something you have: hardware token/phone), and Inherence (something you are: biometric fingerprint). Combining a password with a fingerprint uses Knowledge + Inherence.
Answer: (C)

Q12. Which section of the Information Technology Act 2000 was struck down by the Supreme Court of India in 2015 for violating the fundamental right to freedom of speech and expression?

(A) Section 43
(B) Section 66
(C) Section 67
(D) Section 66A

Sol. Q12. In the historic **Shreya Singhal v. Union of India (2015)** judgment, the Supreme Court of India struck down Section 66A of the IT Act, ruling that its vague criminalization of "offensive" online messages unconstitutionally infringed upon the right to freedom of speech.
Answer: (D)

Q13. Which category of malware disguises itself as an attractive, legitimate utility application but secretly installs an unauthorized backdoor to allow remote attacker access?

(A) Trojan Horse
(B) Boot Sector Virus
(C) Network Worm
(D) Macro Virus

Sol. Q13. A Trojan Horse masquerades as a benign or useful program (such as a game or media player) to trick users into executing it. Once launched, it opens unauthorized backdoors, establishes remote access, and never replicates.
Answer: (A)

Q14. Why is an asymmetric cryptographic algorithm like RSA combined with a symmetric algorithm like AES in modern secure protocols such as HTTPS / TLS?

(A) Because symmetric encryption cannot encrypt binary files
(B) Because asymmetric encryption solves the key distribution problem, while symmetric encryption provides high-speed bulk data encryption
(C) Because symmetric encryption does not use mathematical keys
(D) Because asymmetric encryption is faster than symmetric encryption for large data streams

Sol. Q14. Asymmetric encryption enables secure public key exchange without prior shared secrets, but is computationally slow. Modern protocols use asymmetric encryption during the initial handshake to authenticate and exchange a symmetric session key, and then switch to high-speed symmetric AES for bulk payload encryption.
Answer: (B)

Q15. What is the primary role of a Certifying Authority (CA) within Public Key Infrastructure (PKI)?

(A) To store and backup all user private keys on central government servers
(B) To filter network packets and prevent Denial of Service attacks
(C) To verify an applicant's identity and issue a digitally signed Digital Certificate binding their identity to their public key
(D) To crack and decrypt intercepted encrypted communications

Sol. Q15. A Certifying Authority (CA) is a trusted entity licensed under the IT Act that validates the legal identity of an applicant and issues an X.509 Digital Certificate containing the applicant's public key, digitally signed with the CA's private key to guarantee authenticity.
Answer: (C)